

Understand the 10 concepts that
power 90% of cybersecurity
interviews and exams.

TOP 10 Cybersecurity Concepts

Beginner-friendly guide

Stop learning random topics.
Start with what actually matters.

If you understand these 10 concepts,
cybersecurity will finally make sense.

Decoded

Security

FREE

Cybersecurity Fundamentals: The 10 Concepts That Get You Through 90% of Interviews

Table of contents

Introduction.....	5
Who am I?.....	6
What can you expect from this book.....	7
1. The CIA Triad [General concept].....	8
Confidentiality.....	9
Integrity.....	10
Availability.....	11
2. Data Security Lifecycle.....	12
The 6 Phases You Must Know.....	13
1. Acquisition (Creation / Collection).....	13
2. Storage.....	14
3. Use.....	15
4. Sharing.....	15
5. Archival.....	16
6. Destruction - CRITICAL.....	16
Challenge.....	17
3. Risk Management Fundamentals (the foundation).....	19
What Is Risk?.....	19
Example.....	20
Challenge.....	20
The 6-Step Risk Management Process.....	20
Step 1: Define Scope and Objectives.....	21
Step 2: Define Risk Criteria.....	22
Step 3: Identify Threats and Vulnerabilities.....	22
Step 4: Analyze and Evaluate Risks.....	23
Step 5: Treat the Risk.....	23
Step 6: Monitor and Review.....	23
4. Networking Basics (must-have for every role).....	25
ISO/OSI model.....	26
Network devices.....	27
Repeater.....	27
Bridge.....	27
Switch.....	27
Router.....	28
Gateway.....	28
Proxy Server.....	28
Firewalls.....	29
Firewall Types You Should Know.....	29
Packet Filtering Firewall (Stateless).....	29

Stateful Firewall.....	30
Proxy Firewall.....	30
Next-Generation Firewall (NGFW).....	30
Challenge.....	30
Network protocols.....	31
HTTP / HTTPS: Web Communication.....	32
TCP (Transmission Control Protocol).....	33
UDP (User Datagram Protocol).....	34
Where UDP Is Used.....	34
SMTP (Simple Mail Transfer Protocol).....	35
FTP (File Transfer Protocol).....	36
Chapter Challenge.....	37
5. Cryptography Basics.....	38
Encryption.....	38
Symmetric Encryption.....	38
Exam & Interview.....	39
Asymmetric Encryption.....	39
Symmetric vs Asymmetric encryption.....	41
Hashing.....	42
Encryption vs Hashing.....	43
Key Takeaways.....	43
Chapter Challenge.....	43
6. Identity & Access Management (IAM).....	44
Authentication vs Authorization.....	45
What Is IAM?.....	46
Principle of Least Privilege.....	47
Access Control Models.....	47
DAC (Discretionary Access Control).....	48
MAC (Mandatory Access Control).....	49
• Access is based on security labels (classification levels).....	49
• Enforced by the system, not the user.....	49
• Common in military, government, and high-security environments.....	49
Benefits:.....	49
• Strong, centralized control.....	49
• Very secure for sensitive data.....	49
Drawbacks:.....	49
• Inflexible and hard to manage.....	49
• Not practical for most business environments.....	49
RBAC (Role-Based Access Control).....	49
ABAC (Attribute-Based Access Control).....	50
Key Takeaways.....	51

7. Incident Response.....	53
What Is Incident Response?.....	53
The Purpose of Incident Response.....	53
The 7 Phases of Incident Response.....	53
1. Detection & Identification.....	54
2. Response (Containment).....	54
3. Mitigation (Eradication).....	54
4. Reporting.....	54
5. Recovery.....	54
6. Remediation.....	55
7. Lessons Learned.....	55
Quick Reference: The 7 Phases.....	55
Exam & Interview Tips.....	56
Key Takeaways.....	56
Chapter Challenge.....	57
8. Governance, Policies & Compliance.....	58
What Is Governance?.....	58
The Building Blocks: Policy, Standard, Procedure, Guideline.....	58
How They Connect.....	60
A Real-World Example: The Coffee Shop.....	60
Exam & Interview Tips.....	61
Key Takeaways.....	61
Chapter Challenge.....	61
9. Security Control Types.....	63
Two Ways to Classify Controls.....	63
Classification 1: How Is It Implemented?.....	63
Classification 2: What Purpose Does It Serve?.....	64
Why This Matters in Interviews.....	65
Exam & Interview Tips.....	66
Key Takeaways.....	66
Chapter Challenge.....	67
Cloud Security Basics.....	68
Why Cloud Security Is Non-Negotiable.....	68
The 3 Service Models You Must Know.....	68
The 4 Deployment Models.....	70
The Shared Responsibility Model.....	70
Exam & Interview Tips.....	71
Key Takeaways.....	71
Chapter Challenge.....	72
Congratulations!.....	73
A Small Reward for Finishing.....	73

Stay Connected.....74

WELCOME TO DECODED SECURITY

Cybersecurity Manager | CISSP

Helping people break into cybersecurity

*Certification guides, study tips, and
real-life cyber security stories*



**Decoded
Security**



@cybersecerich



decodedsecurity



@decodedsecurity



@winkleri



Decoded Security



@decodedsecurity

Introduction

Congratulations on starting your cybersecurity journey.

I know cybersecurity can be very confusing in the beginning. There are countless complex topics, roles, and certifications.

You have no idea where to start.

**And when you finally get an interview, you realize something uncomfortable:
You don't actually know what they expect you to know.**

So you study everything. And remember nothing.

How do I know?

Because I've been where you are. Early in my career, I jumped from topic to topic with no direction, wasting months on things that never showed up in interviews.

Luckily, I figured it out over the years. But I could have figured it out much sooner if I had known the things in this book.

That's why I decided to put everything you need at the beginning in one place.

And save you years of struggling.

If you master these 10 areas, you'll be able to confidently answer 80–90% of common cybersecurity interview questions.

So if you're someone who wants to speed up your journey, you're in the right place.

Who am I?

Who is this guy? And why should I even listen to him?

If those are the questions in your head, I understand.

I'm a skeptical person myself. I don't take advice without knowing the source. So let me introduce myself.

My name is Erich, and I'm a CISSP-certified Cybersecurity Manager.

One of my biggest accomplishments was becoming a Cybersecurity Manager at 26 for an international company.

Like most people, I didn't start my career with a perfect roadmap. I was confused, jumping between topics and trying to learn everything at once.

But over time, I started noticing patterns.

After years of experience, and seeing both sides of the hiring process, I realized something important: Most candidates fail interviews not because they lack intelligence, but because they focus on the wrong things.

That's why I share what actually matters.

I also built a small but growing community called [Decoded Security](#), where I document my journey and teach practical cybersecurity concepts. What started as a simple newsletter has grown into hundreds of readers.

And every week, someone messages me saying they passed an exam or landed a job using my materials.

That's exactly why this guide exists, to help you get there faster.

What can you expect from this book

This is not a comprehensive textbook that covers every technical detail.

This is your starting point.

The goal of this book is simple:

Give you a clear overview of the cybersecurity topics that actually matter when you're applying for entry-level or junior roles.

Instead of overwhelming you with everything, we focus only on the fundamentals that interviewers expect you to understand.

You'll learn:

- what each topic means
- why it matters
- the key concepts you must know
- and how to continue learning on your own

This book won't teach you how to perform every task on the job.

But it will give you the vocabulary, mental models, and confidence to walk into interviews prepared, and to know exactly what to study next.

You will find this book useful if:

- you're at the beginning of your career
- you're completely new to cybersecurity
- you want to switch into cybersecurity
- you feel overwhelmed by the number of topics
- you don't know where to start

If that sounds like you, you're in the right place.

Let's get started.

1. The CIA Triad [General concept]

Remember: Protecting information systems means ensuring the CIA (Confidentiality, Integrity, Availability) of all assets in our information systems.

Remember this sentence. Because this is what you will need from the beginning of your career to the end.

Sounds important, right? So, what is it?

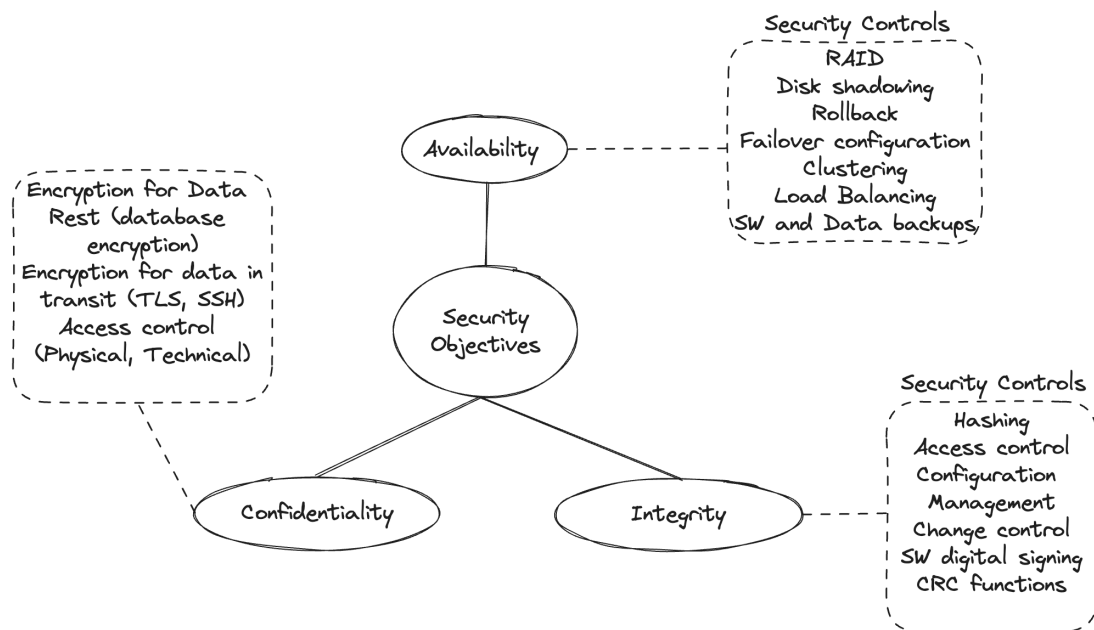
The CIA Triad defines the three core objectives of information security:

Confidentiality: making sure information is only accessible to those who are authorized.

Integrity: ensuring that data hasn't been tampered with or altered without permission.

Availability: making sure systems and data are accessible when needed.

Every control, every policy, every process. It should all come back to supporting one or more of these three pillars.



I know, it might sound a little abstract right now. So let me give you a couple of examples.

Confidentiality

Goal: Only the right people can see the data.

Real-world examples:

HR files accessible only to HR staff

Nobody can see your password

Nobody can access your email

You don't want other people to have access to your email. That's why you use password and hopefully 2FA.

Everything that prevents unauthorized access supports confidentiality.

In simple terms:

If the wrong person can't see it, confidentiality is working.

Integrity

Goal: Data remains accurate, complete, and unchanged unless modified by authorized users.

But wait, how is this different from confidentiality? Don't we just want to keep our data secure?

Well, yes. But often you don't care if everyone can see the data. You just need it to be accurate.

Imagine someone changes a bank account number on a public website.

Is it supposed to be visible to everyone? Yes.

Is it a big problem if it isn't accurate? Yes.

See? Integrity often needs to be enforced even when confidentiality isn't the highest priority.

In simple terms:

If you can verify that the data hasn't been tampered with, integrity is working.

Availability

Goal: Systems and data are accessible when authorized users need them.

But wait, if the data is confidential and accurate, isn't that enough?

We are almost there!

If users can't access the system, the business can't operate.

Imagine your company's website or payment system goes down for an entire day.

Is the data still confidential? Yes.

Is the data still accurate? Yes.

Can anyone use it? No.

That's still a security failure.

Everything that keeps systems running and recoverable supports availability.

In simple terms:

If users can access what they need, when they need it, availability is working.

If you want to know more about the CIA Triad → [Decoded Security: 3 Things](#)

[You Need To Know For Your First Cybersecurity Interview](#)

Challenge:

Go to the article: [Decoded Security: 3 Things You Need To Know For Your First Cybersecurity Interview](#)

In the comments, write: One real-world example of Confidentiality, Integrity, or Availability from your daily life (not cybersecurity work, real life).

I will personally give you feedback!

Why?

If you can recognize the CIA Triad in everyday situations, you're already thinking like a cybersecurity professional.

2. Data Security Lifecycle

Information security is ultimately about protecting data.

Shocking, right?

But data isn't static.

It moves, changes, gets copied, shared, archived, and eventually destroyed.

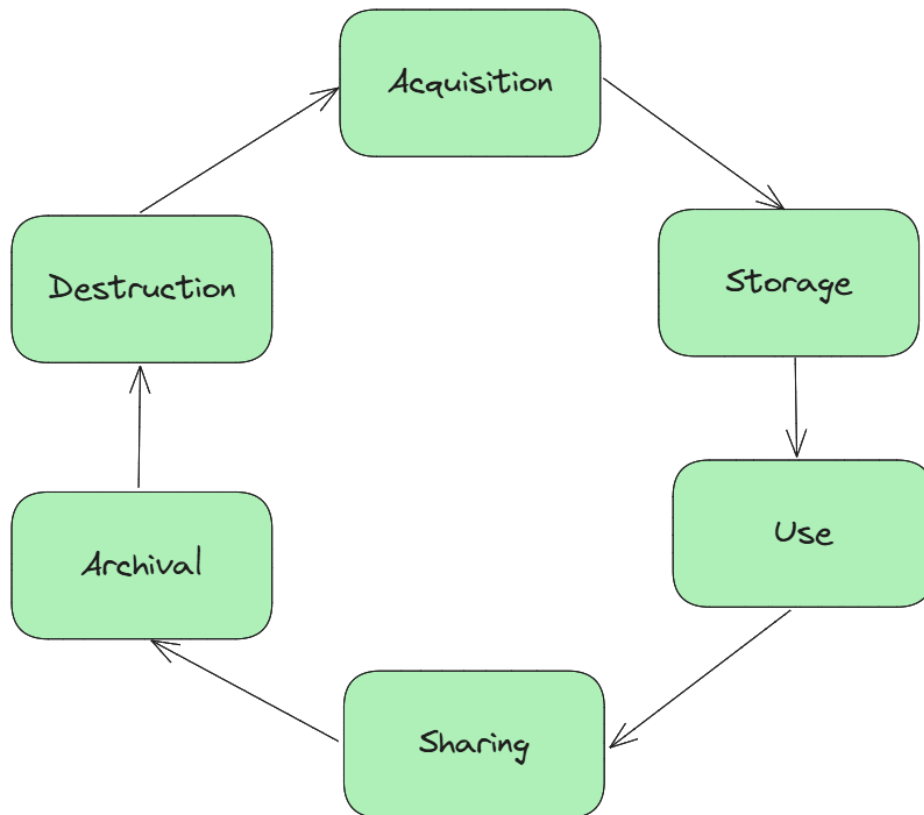
And you need to keep track. You can't protect something you don't understand.

Each stage introduces different risks.

The data lifecycle helps security professionals apply the right controls at the right time.

If you understand this model, you automatically think more like a security professional, and this comes up frequently in interviews and certifications like ISC2 exams.

The 6 Phases You Must Know



1. Acquisition (Creation / Collection)

It all starts when we create the data.

Generally speaking, data is acquired by an organization in one of three ways:

- Collected directly: e.g., a customer fills out a registration form, an employee clocks in with a badge, or a sensor records temperature in a warehouse.
- Copied from elsewhere: e.g., importing a supplier's product catalog, downloading data from a government open-data portal, or syncing customer records from a partner system.
- Created from scratch: e.g., a financial analyst builds a forecast spreadsheet, a developer generates test data for an application, or a marketing team creates a new customer segment list.

Why is it tricky?

Because we must be careful about what we collect, especially when it comes to personal data.

Any data that we collect can become a liability. The reasons are beyond the scope of this book, but make sure you understand that there are many privacy laws that limit data collection.

2. Storage

Once collected, data has to live somewhere.

Databases. File servers. Cloud systems.

This is the “warehouse phase.”

Examples:

- Customer data stored in a CRM
- Employee contracts in an HR system
- Medical records in hospital databases

But storage isn't just dumping files into a folder.

To securely store data, we need to ensure the following things:

- Confidentiality: Only authorized people have access to the data
- Availability: The data won't disappear
- Integrity: There will be no unauthorized changes to the data.

And to achieve this, you typically need to assign metadata, such as:

- Who owns the data
- Classification level (public, internal, confidential)
- Creation date and access history
- Backup and retention information

This metadata allows organizations to enforce policies:

- Who can access the data
- How long it should be kept
- Which compliance rules apply

Risks: exposed databases, weak access control, unencrypted backups.

At this stage, there are generally three main controls: Encrypt it. Restrict access. Back it up!

Small Favor (Helps More Than You Think)

If this book helped you understand cybersecurity concepts more clearly, I would really appreciate your support.

Please consider leaving a short review on Gumroad.

Your feedback helps:

- Other beginners decide whether this guide is worth their time
- More people discover cybersecurity
- Me continue creating free educational content

Even one sentence makes a difference.

3. Use

This is why data exists in the first place, to be used.

But from a security perspective, this is one of the most complex stages.

You want data:

- Accessible to authorized users
- Modifiable only in approved ways
- Consistent with policies and regulations

We should have everything prepared from the previous phase, but here is the problem - the data keeps changing!

Adding sensitive information to a document can change its classification level.

That means controls must adapt dynamically.

Key idea: Data use is a balancing act between usability and control.

4. Sharing

Modern organizations constantly share data:

- Employees
- Contractors
- Vendors
- Partners

Data sharing enables business operations, but also introduces major risk.

Problems occur when:

- Data goes to the wrong recipient
- Channels aren't secure
- Policies aren't followed
- Third parties mishandle information

Best practices:

- Share only what is necessary
- Use secure channels and encryption
- Track who has access
- Use contractual protections with third parties

Key idea: Sharing fuels business, but only if controlled.

5. Archival

Eventually, data stops being used regularly.

So what do we do?

We archive it.

But we don't archive data just for fun.

Reasons include:

- Legal and regulatory requirements
- Audits and investigations
- Historical analysis
- Business continuity

Archiving requires:

- Proper classification
- Secure storage
- Retention policies defining how long data is kept

Keeping data too long is risky.
Deleting it too early is also risky.

Key idea: Archival is about balance.

6. Destruction - CRITICAL

Finally, data reaches the end of its life.

And here's a common mistake:

Deleting a file is not the same as destroying data.

Most people think the story ends once the data is deleted. But we need to completely change the definition of what "deleted" means.

Proper destruction depends on the medium:

- Physical drives → wiping, degaussing, shredding
- Cloud systems → secure deletion procedures

If you want to learn more about secure data destruction (and I think you should), here it is in more detail → [The Final Goodbye: How to Dispose Data So It Never Comes Back](#)

Improper destruction can lead to:

- Data breaches
- Legal penalties
- Compliance violations

Many regulations require documented destruction processes.

Key idea: If data still exists, it can still leak.

Challenge

At first glance, the data lifecycle might seem boring.

But once you realize how many security failures happen because organizations lose track of data, it becomes extremely important.

This simple security lifecycle helps organization to ensure security of data from the beginning to the end - from creation to destruction.

And because I think the best way to learn is to create examples I have a small challenge for you.

Go to the article: [The Data Lifecycle: From Creation to Secure Destruction](#)

And in the comments, write: One example of data from your daily life and identify which lifecycle phase it is currently in.

Examples:

- **Photos on your phone**
- **Bank transactions**
- **University records**
- **Emails**
- **Cloud backups**

If you can recognize lifecycle phases in real situations, you're already thinking like a security professional.

I read the comments, join the discussion. Let's learn together!

3. Risk Management Fundamentals (the foundation)

If there is one concept that separates beginners from professionals in cybersecurity, it's this:

Cybersecurity is not about **eliminating risk**. It's about **managing risk**.

This might sound obvious, but it isn't.

Organizations don't implement security controls because they look cool. They implement them because something valuable could be lost.

Money. Reputation. Operations. Data. Human safety.

But at the same time, someone has to pay for the security measures that are implemented.

And businesses exist to generate money, not to implement security controls.

Risk management is the process that connects security decisions to business reality.

What Is Risk?

First, you need to clearly understand the difference between risk, threat, and vulnerability.

These terms are often confused, even by people already working in IT.

But they are the foundation of cybersecurity thinking.

Here is the most important idea: A threat exploits a vulnerability to impact an asset.

And risk is the possibility that this will happen.

Simple Definitions

- **Asset** → Something valuable
(data, systems, people, reputation, money)
- **Threat** → Something that could cause harm
(hackers, malware, human mistakes, natural disasters)
- **Vulnerability** → A weakness that can be exploited
(unpatched software, weak passwords, misconfiguration, poor training)

- Risk → The likelihood that a threat exploits a vulnerability and the resulting business impact.

Example

Again, let me give you an example to make it easier for you.

Asset: Customer database

Vulnerability: Weak authentication

Threat: Attacker guesses password

Risk: Data breach and business damage

Threats exploit vulnerabilities to impact assets.

That sentence alone appears constantly in interviews and certifications.

Do you want to go deeper and see how these concepts work in a real-world scenario?

I highly recommend this article:

[Threat ≠ Risk ≠ Vulnerability: Why CISSP Basics Matter More Than You Think](#)

It walks through practical examples and explains how professionals think about these terms in practice.

Challenge

Go to the article: [Threat ≠ Risk ≠ Vulnerability: Why CISSP Basics Matter More Than You Think](#)

And create your own real-world example in the comments!

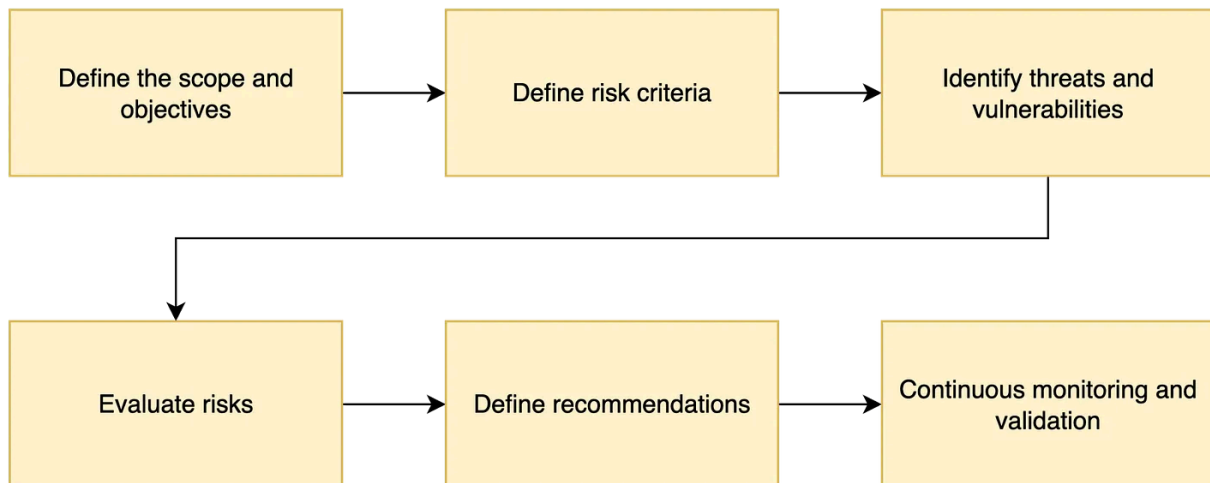
If you can create your own examples, you truly understand the concept.

I will give you feedback!

The 6-Step Risk Management Process

Now that we know the terms it is time to describe the risk management process itself.

Remember, this is a very general concept, but it works regardless of any frameworks.



Step 1: Define Scope and Objectives

Before analyzing risks, you must decide:

What are we assessing?

Examples:

- **A cloud system**
- **A company network**
- **A business process**
- **An application**

You also identify:

- **Assets**
- **Stakeholders**
- **Business goals**

Important principle:

Security must align with business objectives.

Step 2: Define Risk Criteria

We need rules to evaluate risk consistently.

Typically we define:

Impact levels

- **Financial damage**
- **Operational disruption**
- **Legal consequences**
- **Reputational harm**

Likelihood levels

- **Rare**
- **Possible**
- **Likely**

We also define risk tolerance:

What level of risk is acceptable?

This decision belongs to management, not security teams.

Step 3: Identify Threats and Vulnerabilities

Now we ask:

What could go wrong?

We connect:

Asset → Vulnerability → Threat → Risk

Frameworks like the CIA Triad help identify what could be impacted:

- **Confidentiality**
- **Integrity**
- **Availability**

The output of this step is usually a risk register, a documented list of risks.

Step 4: Analyze and Evaluate Risks

Not all risks are equal.

We prioritize based on:

Likelihood × Impact

This can be:

- **Qualitative (High / Medium / Low)**
- **Quantitative (financial estimation)**

The goal is prioritization, not perfection.

Step 5: Treat the Risk

Once we understand risk, we decide what to do.

There are four classic options you must remember:

1. **Mitigate → Reduce the risk with controls**
2. **Transfer → Shift the risk to someone else**
3. **Accept → Do nothing (risk is tolerable)**
4. **Avoid → Eliminate the activity entirely**

You are not aiming for zero risk.

You are aiming for acceptable risk.

Step 6: Monitor and Review

Risk management is not a one-time activity.

Systems change. Threats evolve. Businesses grow.

So we continuously:

- **Monitor controls**
- **Detect new risks**
- **Reassess priorities**
- **Update the risk register**

Remember: Risk management is a continuous cycle.

If this is all too theoretical, here is a real world example from a cloud environment:
[Example: Risk Management for a Cloud Environment](#)

Congratulations, you're making great progress!

Trust me, if someone asks you about risk management and you can clearly describe this process, you will immediately stand out.

Small Favor (Helps More Than You Think)

If this book helped you understand cybersecurity concepts more clearly, I would really appreciate your support.

Please consider leaving a short review on Gumroad.

Your feedback helps:

- **Other beginners decide whether this guide is worth their time**
- **More people discover cybersecurity**
- **Me continue creating free educational content**

Even one sentence makes a difference.

Thank you for being part of this journey

4. Networking Basics (must-have for every role)

Here's the reality: Most cyberattacks happen through network communication.

That's why when people start learning cybersecurity, they often hear the same advice: "You need to learn networking."

And that's correct.

But here's the problem: Networking is huge.

There are hundreds of protocols, devices, standards, and concepts. Beginners often try to learn everything at once and end up overwhelmed.

The good news?

You don't need to know everything.

If you understand the core communication principles and a few key protocols, you already have a strong foundation for cybersecurity.

If you don't understand how systems talk to each other, you won't understand how attackers exploit them.

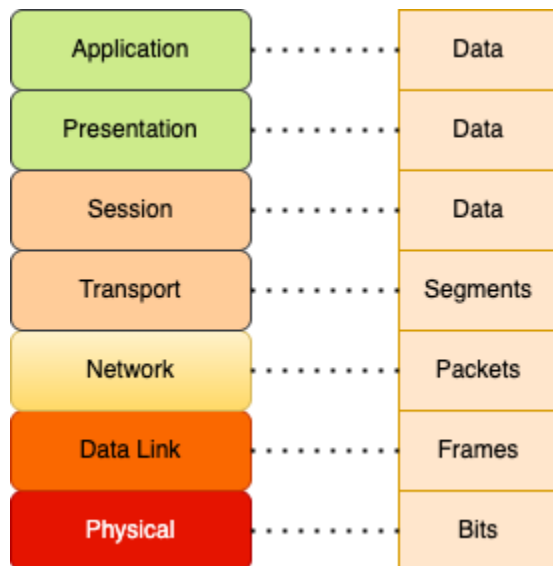
It's that simple.

ISO/OSI model

First thing you need to understand is it ISO/OSI model.

There are 7 layers:

1. Physical: cables, signals, hardware
2. Data Link: MAC addresses, switches
3. Network: IP addressing, routing
4. Transport: TCP, UDP
5. Session: connection management
6. Presentation: encryption, formatting
7. Application: protocols users interact with (HTTP, SMTP, FTP)



You don't need to memorize every detail.

What matters is understanding that different technologies operate at different layers. This helps you troubleshoot problems and understand attacks.

The concept is described in more details here: [Understanding the ISO/OSI Model – Why is it crucial for Cybersecurity professionals?](#)

Network devices

Before we talk about protocols and attacks, you should understand the basic devices that make networks possible.

You don't need deep technical knowledge yet, just understand why the devices exists.

Let's take a look!

Repeater

A repeater is the simplest network device.

Its job is to regenerate a weak signal so data can travel further.

It does not understand addresses, packets, or traffic.

Security relevance: Very low.

Today mostly replaced by more advanced devices.

Bridge

A bridge connects two network segments and forwards traffic using MAC addresses (Layer 2).

It reduces unnecessary traffic compared to older devices like hubs.

Modern switches are essentially advanced multi-port bridges.

Security relevance: Limited, but vulnerable to MAC flooding and broadcast issues.

Switch

A switch connects devices inside the same network (LAN).

It forwards traffic based on MAC addresses and creates separate collision domains for each port, improving performance.

Modern switches can support:

- VLANs (network segmentation)
- Port security
- Layer 3 routing (multilayer switches)

Security relevance: Important.

Misconfigurations can lead to VLAN hopping or traffic interception.

Router

A router connects different networks together and forwards traffic using IP addresses (Layer 3).

Example: Your home router connects your internal network to the internet.

Routers often provide:

- **Network Address Translation (NAT)**
- **Access Control Lists (ACLs)**
- **Basic traffic filtering**

Security relevance: Very high.

Routers define network boundaries and are critical control points.

Gateway

A gateway connects networks that use different protocols or architectures.

It acts as a translator between systems that otherwise could not communicate.

Examples:

- **Email gateways**
- **VoIP gateways**
- **API gateways**

Security relevance: High.

Gateways often sit between internal and external environments.

Proxy Server

A proxy is an intermediary between a client and a server.

It operates at the Application layer.

There are two main types:

Forward Proxy

- **Between users and the internet**
- **Filters outgoing traffic**

- Enforces policies

Reverse Proxy

- Between the internet and internal servers
- Protects backend systems
- Often used for load balancing and security

Security relevance: Very high.

Proxies are important control points for monitoring and filtering traffic.

If you want to learn more details and real-world examples, read the article:

[What are the things that keep our networks alive?](#)

Firewalls

Imagine your house with no doors.

Anyone could walk in. Anytime.

That's exactly what a network would look like without a firewall.

When people think about cybersecurity, they often think about firewalls first. And while cybersecurity is much more than that, firewalls are still one of the most important protections we have.

At a basic level, a firewall: Monitors and controls network traffic based on security rules.

It decides what is allowed to enter or leave a network.

You can think of it as a security guard for digital traffic.

Firewall Types You Should Know

You don't need deep technical knowledge yet, just understand the main differences.

Packet Filtering Firewall (Stateless)

This is the easiest one.

Decisions are based only on:

- IP addresses
- Ports
- Protocols

It does not remember connections.

Fast, but limited protection.

Stateful Firewall

Tracks active connections and remembers sessions.

Much smarter decisions because it understands context.

Most traditional enterprise firewalls are stateful.

Proxy Firewall

Acts as an intermediary between client and server.

Client → Firewall → Server

Provides deeper inspection and stronger security, but slower performance.

Next-Generation Firewall (NGFW)

Modern firewalls combine multiple capabilities:

- Stateful inspection
- Intrusion prevention
- Application awareness
- User identity integration

High protection, but more complex and expensive.

Here's something important: A firewall alone does not make a system secure.

It's one layer of defense, not the whole solution.

Challenge

Go to the article: [The Complete Guide to Firewall Types: From Packet Filters to Next-Gen](#)

And in the comments write: What is the difference between a stateful and stateless firewall?

If you can explain that clearly, you truly understand firewalls. I read the comments and will give you feedback.

Small Favor

If this guide is helping you understand cybersecurity concepts more clearly, please consider leaving a short review on Gumroad.

Even one sentence helps other beginners discover it and helps me continue creating practical content.

Thank you for being part of this journey

Erich
Decoded

Security

Network protocols

The Rules of Communication, and How Attackers Break Them

Now we're getting to something that actually matters.

If networking devices are the roads and infrastructure of a city, then protocols are the laws of the road, the agreed-upon rules that govern how traffic flows, how vehicles identify themselves, and what happens when something goes wrong.

In cybersecurity, almost every attack exploits communication. A hacker doesn't usually break down a physical door. They send carefully crafted messages through the normal channels your systems use every day. If you don't understand how those channels work, you won't recognise when they're being abused.

The good news: you don't need to memorise every protocol in existence. There are five that will give you the foundation you need to understand the vast majority of real-world attacks:

- HTTP/HTTPS
- TCP
- UDP
- SMTP
- FTP

Master these five, and you'll have a solid understanding of how systems talk to each other, and how attackers listen in.

HTTP / HTTPS: Web Communication

OSI Layer: Application Layer (Layer 7)

Every time you open a website, your browser and a server are having a conversation using HTTP - the Hypertext Transfer Protocol. It's the foundation of how the web works.

HTTP follows a simple request-response model: your browser sends a request, the server processes it, and the server sends back a response. That's it. Open a page, send a request, receive the content.

HTTP Methods

HTTP requests come in different types depending on what you're trying to do. You'll see four methods repeatedly in security contexts:

- **GET:** retrieve data from a server (loading a webpage)
- **POST:** send data to a server (submitting a login form)
- **PUT:** update existing data
- **DELETE:** remove data

These methods appear in interview questions, penetration testing tools, and vulnerability reports constantly. Know them.

Status Codes

When a server responds, it includes a three-digit status code that tells you what happened. A few you'll encounter regularly:

Cod e	Meaning
200	Success: the request worked
301 / 302	Redirect: the resource has moved
403	Forbidden: you don't have permission
404	Not found: the resource doesn't exist
500	Server error: something went wrong on the server's end

HTTP vs HTTPS

HTTP transmits data in plain text. That means anyone monitoring the network can read it: usernames, passwords, session tokens, everything.

HTTPS adds a layer of TLS encryption, which scrambles the data in transit. Even if an attacker intercepts it, they can't read it.

Why It Matters for Security

The majority of internet traffic is web traffic, which means most attacks happen over HTTP and HTTPS. Understanding this protocol is the first step to understanding:

- Man-in-the-Middle (MitM) attacks: intercepting unencrypted HTTP traffic
- Session hijacking: stealing authentication tokens from HTTP responses
- Cross-Site Scripting (XSS): injecting malicious scripts into web pages
- SQL Injection: sending malicious input through HTTP POST requests

TCP (Transmission Control Protocol)

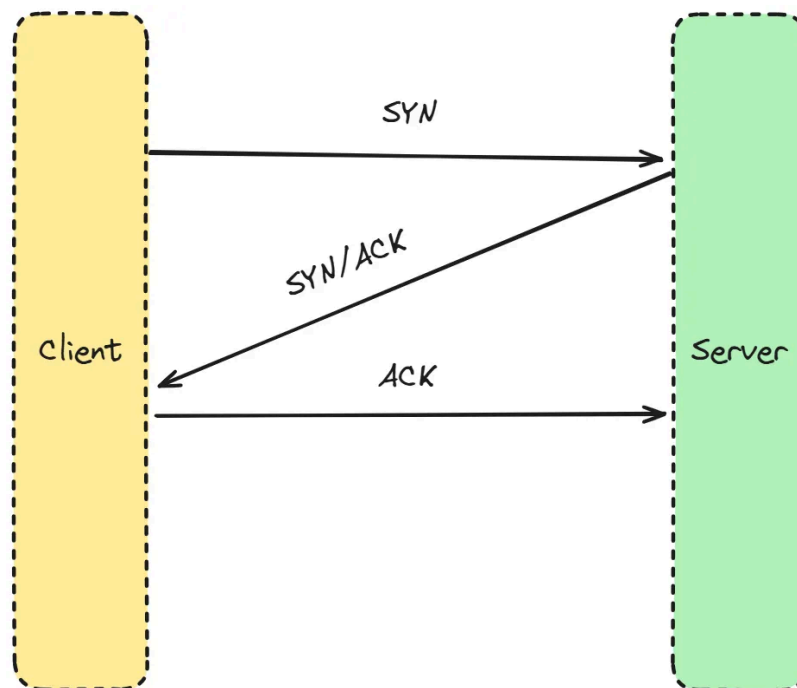
OSI Layer: Transport Layer (Layer 4)

TCP is the protocol that makes reliable communication possible between two devices on a network. When you need data to arrive correctly, in the right order, without anything missing, TCP is doing that work.

Think of it as a tracked delivery service. You know the package was sent, you know it arrived, and if anything went wrong along the way, it gets sent again.

The Three-Way Handshake

Before any data is exchanged, TCP establishes a connection through a process called the three-way handshake. This is one of the most important concepts in networking, and it comes up constantly in certifications, interviews, and security tools.



This handshake is the foundation of every TCP connection, whether you're loading a webpage, sending an email, or logging into a remote server.

Why It Matters for Security

Understanding TCP unlocks your ability to understand a wide range of attacks and security concepts:

- Port scanning: tools like Nmap use TCP connections to discover open ports on a target system
- SYN flood attacks: attackers send thousands of SYN requests but never complete the handshake, exhausting the server's resources (a form of denial-of-service)
- Session hijacking: attackers can intercept and take over an established TCP connection
- Firewall rules: firewalls inspect TCP connections and decide which to allow or block

You cannot understand network security without understanding TCP. It's that foundational.

UDP (User Datagram Protocol)

OSI Layer: Transport Layer (Layer 4)

Where TCP is careful and methodical, UDP is fast and indifferent. It sends data without establishing a connection, without checking whether it arrived, and without caring about order.

Think of UDP like dropping a stack of leaflets from a moving van. You don't know how many landed. You don't know if they're in the right order. You don't stop to check.

TCP: Reliability > Raw Speed
UDP: Reliability < Raw Speed

Where UDP Is Used

That lack of reliability isn't always a problem. For certain applications, speed matters far more than perfection:

- DNS - domain name lookups need to be instant; a dropped packet just means a quick retry
- Video streaming - a dropped frame is better than a frozen screen
- Online gaming - real-time position data needs to be fast, not perfect
- Voice calls (VoIP) - a split-second gap in audio is preferable to a delay

Why It Matters for Security

UDP's lack of overhead makes it extremely attractive to attackers. Because there's no handshake and no verification, it's easy to send massive volumes of traffic very quickly, and easy to fake where that traffic is coming from.

UDP is heavily abused in DDoS (Distributed Denial of Service) amplification attacks, where attackers exploit UDP-based services to flood a target with far more traffic than they originally sent.

TCP vs UDP

Feature	TCP	UDP
Connection	Connection-oriented (handshake)	Connectionless (no handshake)
Reliability	Guaranteed delivery	No delivery guarantee
Speed	Slower (more overhead)	Faster (minimal overhead)
Order	Data arrives in order	No ordering guarantees
Use cases	Web, email, file transfer	DNS, streaming, gaming, VoIP
Attack surface	SYN floods, session hijacking	DDoS amplification, flooding

Being able to explain this comparison clearly and confidently is something interviewers specifically look for.

SMTP (Simple Mail Transfer Protocol)

OSI Layer: Application Layer (Layer 7)

SMTP is the protocol responsible for sending email. Every time you hit send on an email, SMTP is what carries it from your mail client to your mail server, and from there to the recipient's mail server.

It's worth noting what SMTP does and doesn't do: it handles sending. Retrieving email is handled by separate protocols, IMAP and POP3. SMTP is purely the outbound mechanism.

The Security Problem with SMTP

SMTP was designed in the early days of the internet, when trust between systems was assumed. It was never built with strong authentication or verification in mind.

That oversight has had enormous consequences.

By default, SMTP doesn't verify that the sender is who they claim to be. This is why email spoofing, sending an email that appears to come from a trusted address is so easy.

To address this, three additional standards were developed:

- **SPF (Sender Policy Framework): specifies which servers are authorised to send email for a domain**
- **DKIM (DomainKeys Identified Mail): adds a cryptographic signature to verify the email hasn't been tampered with**
- **DMARC: ties SPF and DKIM together and tells servers what to do when checks fail**

Many organisations still don't have all three configured correctly, which is part of why phishing remains so effective.

Why It Matters for Security

Email is the number one attack vector in cybersecurity. The majority of ransomware infections, data breaches, and fraud begin with a malicious email. Understanding SMTP is understanding the foundation of:

- **Phishing attacks: deceptive emails designed to steal credentials**
- **Email spoofing: faking the sender address to impersonate a trusted entity**
- **Business Email Compromise (BEC): high-value fraud targeting executives or finance teams**
- **Malware delivery: attachments and links that install malicious software**

FTP (File Transfer Protocol)

OSI Layer: Application Layer (Layer 7)

FTP was designed to do one thing: move files between systems. It's been around since the early days of the internet, and it does its job. The problem is that it was never designed with security in mind.

FTP uses two separate channels, one for commands and one for data, which is an interesting design choice, but the critical detail is this: neither channel is encrypted.

The Core Problem

When you log into an FTP server, your username and password travel across the network in plain text. The files you transfer do the same. Anyone monitoring that network traffic can intercept everything.

Secure Alternatives

Because of these risks, two secure alternatives were created:

- SFTP (SSH File Transfer Protocol): transfers files over an encrypted SSH connection
- FTPS (FTP Secure): adds TLS encryption to standard FTP

In a modern environment, you should rarely have reason to use unencrypted FTP.

When you encounter it in a professional context, it's usually a legacy system that hasn't been updated, and that makes it a target.

Why It Matters for Security

FTP is one of the first things attackers look for when scanning a network. Exposed FTP servers, weak credentials, and anonymous access are still surprisingly common even in large organisations.

Key Takeaways

If you take one idea from this chapter, let it be this: most cyberattacks don't happen through magic or mystery. They happen through the same communication channels that legitimate systems use every day. Understanding those channels is how you start to see attacks coming.

- HTTP / HTTPS: is how the web communicates; most attacks target it directly
- TCP: provides reliable, ordered delivery and underpins nearly all internet communication
- UDP: trades reliability for speed and is widely abused for flooding attacks
- SMTP: Email - The single biggest attack vector in cybersecurity
- FTP: Transfers files in plain text and remains a common vulnerability in legacy environments

You don't need to become an expert in all of these overnight. But each time you encounter one of these protocols in the real world, in a news story, a security report, or a penetration test, you'll now have context for what's actually happening.

Chapter Challenge

Head over to the article: [Top 5 Most Important Network Protocols for Cybersecurity Beginners](#)

In the comments, answer this question in your own words:

"What is the difference between TCP and UDP, and why does it matter for security?"

Why?

Because that's how you learn. You must get use to explaining these things when everybody is watching.

If you can explain it simply, you genuinely understand it.

I read every comment and will give you feedback!!

5. Cryptography Basics

What Every Exam and Interviewer Expects You to Know

Cryptography is one of the most tested topics across Security+, ISC2 CC, and CISSP. You don't need to understand the mathematics. You need to understand what each concept does and why it exists.

But as always, let's start from the beginning!

Encryption

Encryption converts plaintext (readable data) into ciphertext (unreadable data). Only someone with the correct key can reverse it. It directly supports Confidentiality from the CIA Triad.

There are generally two types of encryption: symmetric and asymmetric. Both have the same goal, yet they are fundamentally different from each other.

The main idea is simple

Plaintext + Key → Ciphertext

Ciphertext + Key → Plaintext

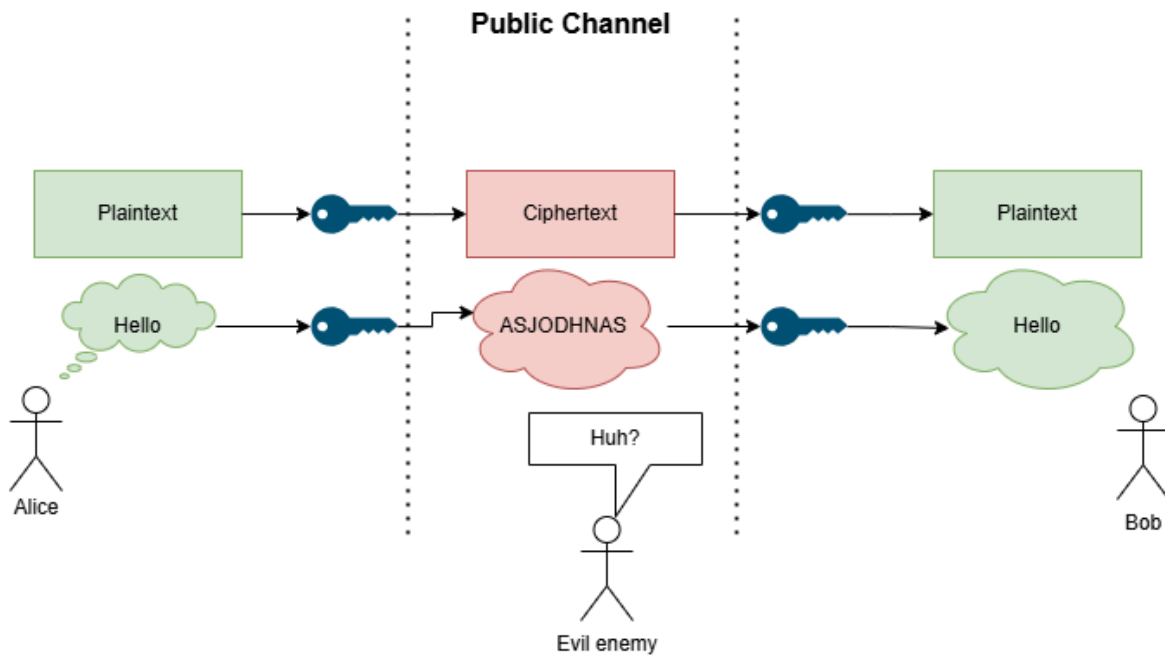
Without the key, ciphertext is useless to an attacker.

Symmetric Encryption

One shared key encrypts and decrypts data. Fast and efficient, the right choice for bulk data encryption.

The weakness: both parties need the same key, and sharing it securely is a problem. This is called the key distribution problem.

Example:



Alice wants to send a message to Bob

1. But Alice doesn't want her evil enemy to see the content of the message.
2. Alice encrypts the message and shares the key with Bob so only he can decrypt it.
3. The evil enemy tries to read the message, but all he sees is gibberish.
4. The issue is to securely share the key with Bob

Exam & Interview

Algorithm to know:

- AES (Advanced Encryption Standard) -the current gold standard.
- 3DES appears on older exams.

Interview Q: What is symmetric encryption and what is its main weakness?

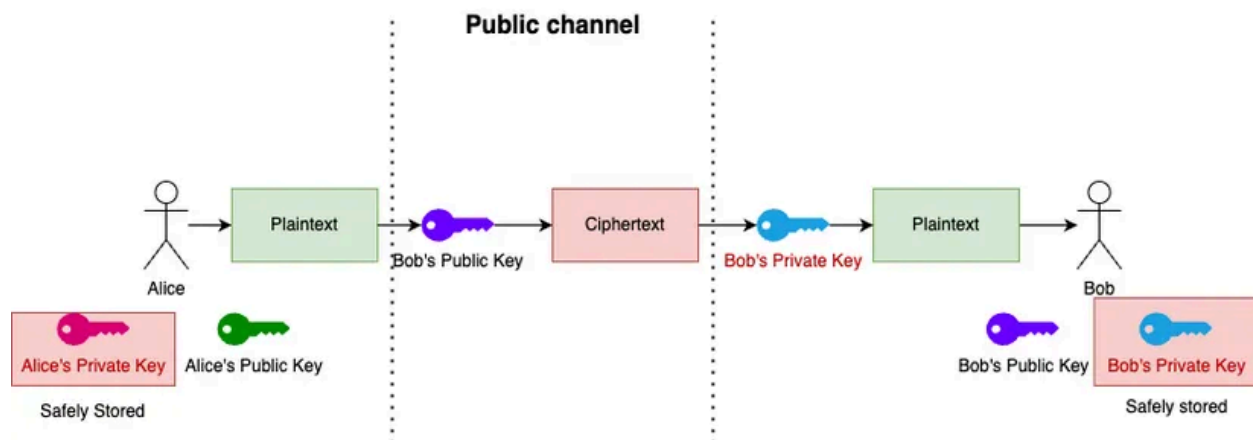
Answer: One shared key for encryption and decryption. Fast, but the key must be exchanged securely, which is the core problem asymmetric encryption solves.

Asymmetric Encryption

Two mathematically linked keys: a public key (shareable with anyone) and a private key (never shared). Data encrypted with the public key can only be decrypted with the private key.

This solves key distribution, but it's significantly slower than symmetric encryption.

If you want to see how asymmetric encryption works on a simple example, just click here: [Symmetric vs Asymmetric Encryption: What's the Difference?](#)



In practice, both are used together. Asymmetric encryption exchanges a symmetric key securely. Symmetric encryption then handles the actual data. This is exactly how HTTPS works.

Exam & Interview

Algorithms to know:

- RSA (most common)
- ECC (smaller keys, same strength)
- [Diffie-Hellman \(key exchange\)](#).

Interview Q: What is the difference between symmetric and asymmetric encryption?

Answer: Symmetric uses one shared key, it is fast but has a key distribution problem.

Asymmetric uses a mathematically linked key pair, which solves key distribution but is slower.

In real systems, both are combined: asymmetric to exchange a key, symmetric to transfer data.

Symmetric vs Asymmetric encryption

Feature	Symmetric	Asymmetric
Keys	One shared key	Public + private key pair
Speed	Fast	Slow
Key distribution	Problem	Solved
Best for	Bulk encryption	Key exchange, digital signatures
Examples	AES, 3DES	RSA, ECC, Diffie-Hellman

Hashing

Now we know what encryption is. Good. If these terms are new to you, make sure to pay attention to the upcoming section.

What is hashing? And why isn't it the same as encryption? It takes the data and create something unreadable...right?

Well...not really. Let's break it down.

Hashing converts any input into a fixed-length output called a hash. It is one-way operation, you cannot reverse a hash to recover the original data.

This is the critical difference from encryption.

Encryption protects data FROM being read. - CONFIDENTIALITY

Hashing proves data HAS NOT BEEN CHANGED - INTEGRITY

Exam & Interview

Algorithms to know:

- MD5 and SHA-1: weak and deprecated. Correct answer when asked what NOT to use.
- SHA-256 / SHA-3: current standards. Correct answer when asked what TO use.

Interview Q: What is hashing and how is it different from encryption?

Answer: Hashing is a one-way process that converts input into a fixed-length hash.

Unlike encryption, it cannot be reversed.

It is used to verify integrity, not protect confidentiality.

If you want to learn more about hashing and the requirements for hashing functions, just click here: [Hashing: What It Is and Why It's Not the Same as Encryption.](#)

Encryption vs Hashing

Property	Encryption	Hashing
Reversible?	Yes, with the correct key	No, one-way only
Purpose	Confidentiality	Integrity
Uses a key?	Yes	No
Output	Variable-length ciphertext	Fixed-length hash
Examples	AES, RSA	SHA-256, MD5 (deprecated)

Key Takeaways

- Encryption: protects confidentiality; reversible with the correct key
 - Symmetric: one key; fast; key distribution is the weakness
 - Asymmetric: key pair; solves distribution; slower; real systems use both together
- Hashing: one-way; cannot be reversed; protects integrity not confidentiality
- The exam question you will get: explain the difference between encryption and hashing

Chapter Challenge

Head over to [Symmetric vs Asymmetric Encryption: What's the Difference?](#) article and leave a comment answering:

"What is the difference between encryption and hashing, and can you give one real-world example of each?"

Because that's how you learn. You must get use to explaining these things when everybody is watching.

If you can explain it simply, you genuinely understand it.

I read every comment and will give you feedback!

6. Identity & Access Management (IAM)

Who gets in, and who doesn't.

Every organisation on the planet has the same problem: valuable data and systems that not everyone should be able to access.

And attackers know this. When they get into a network, the first thing they do is look for accounts with too much access.

One compromised employee account with admin privileges can bring down an entire company.

That's why IAM is not just an IT topic.

It is one of the most common areas tested in Security+, ISC2 CC, and CISSP, and it comes up in almost every entry-level interview.

Interviewers want to know:

- Do you understand how access is controlled?
- Can you explain the difference between the models?
- Do you know what are the best practices?

By the end of this chapter, you will.

But first, we need to get familiar with terms authentication and authorization.

Authentication vs Authorization

Authentication means verifying identity, proving who you are.

Examples:

- Password
- Fingerprint
- Face recognition
- Multi-factor authentication (MFA)

Authorization means determining what you are allowed to do after you are identified.

Examples:

- Access to files
- Permissions in systems
- Administrator rights

The key rule:

Authentication comes first. Authorization comes second.

You cannot authorize someone you haven't authenticated.

What Is IAM?

IAM stands for Identity and Access Management.

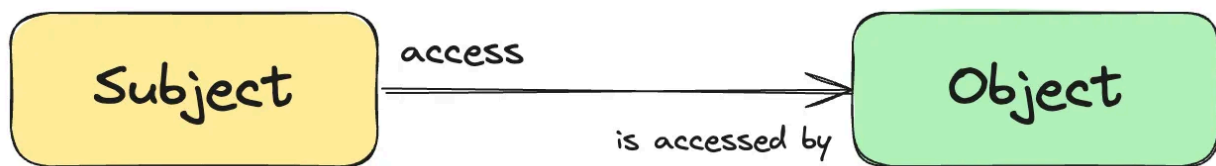
It refers to the policies, processes, and technologies used to control: Who can access what inside an organization, and what they are allowed to do.

In simple terms, IAM answers two questions:

1. Who are you?
2. What are you allowed to do?

Before we go further, you need to understand the following terms:

- Subject → the entity requesting access (user, system, service, process)
- Object → the resource being accessed (file, database, application, system)



No matter what access control model you use the main principle stays the same. You are applying a set of rules that determines which subjects can access which objects.

If you want deeper explanations and real-world company examples, I recommend reading my article: [Access Controls: Who Gets the Keys?](#) [QUIZ included]

Exam & Interview

Interview Q: What is the difference between authentication and authorisation?

Answer: Authentication verifies who you are (proving identity). Authorisation determines what you are allowed to do (granting permissions).

Authentication always comes first. You cannot authorise someone you haven't identified.

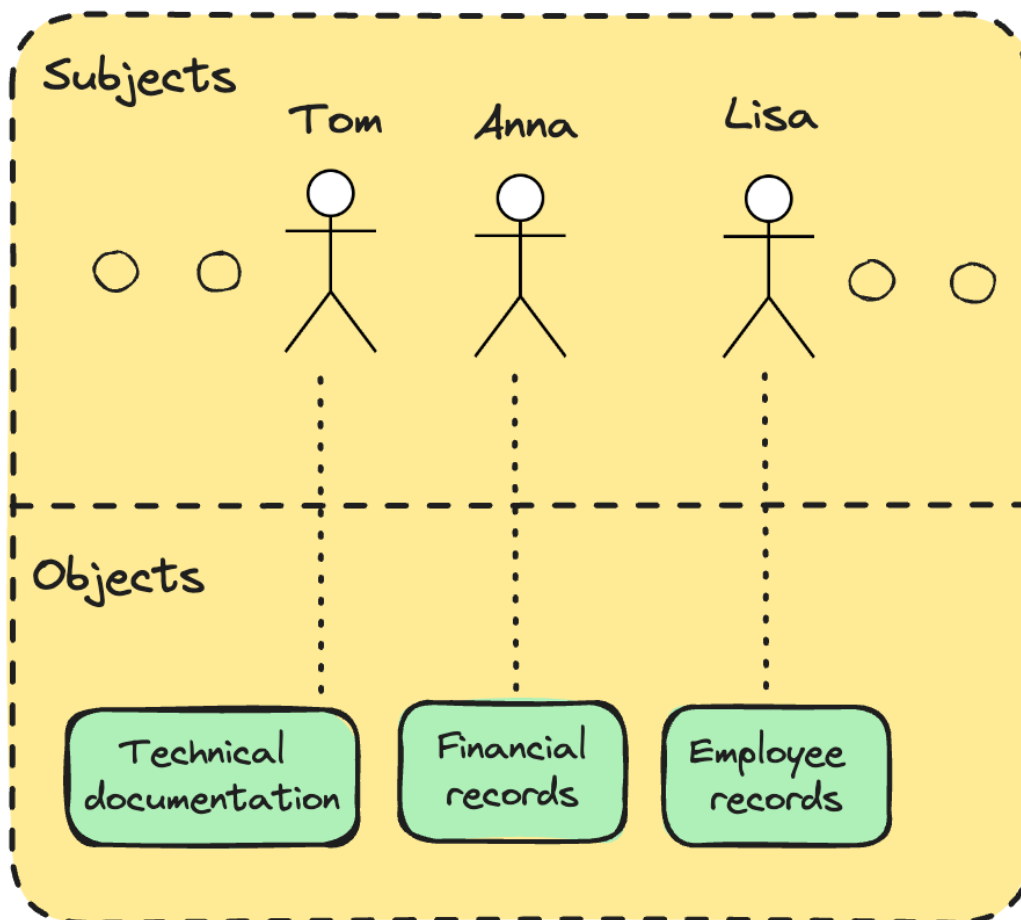
This distinction appears in Security+, ISC2 CC, and CISSP. Know it cold.

Principle of Least Privilege

Every user, process, and system should have the minimum level of access needed to do their job, and nothing more.

Access Control Models

Now that we understand the basic terms, it's time to move to access control models. There are quite a few out there, but today we'll focus on the most common models. The ones you're most likely to encounter in the real world.



DAC (Discretionary Access Control)

The resource owner decides who can access it. You create a file, and you choose who can read or edit it. Simple and flexible, but hard to manage at scale and vulnerable to careless sharing.

Summary:

- Access decisions are made by the resource owner.
- Example: You create a file and decide who can read or edit it.
- Common in personal or small business settings.

Benefits:

- Easy to understand and implement.
- Very flexible for users.

Drawbacks:

- Decentralized - hard to manage in large environments.
- Vulnerable to insider threats and careless permission sharing.

MAC (Mandatory Access Control)

The system enforces access based on security labels, such as "Top Secret", "Confidential", "Unclassified". Users can't override these rules. Common in military and government environments where data classification is strict.

Summary:

- Access is based on security labels (classification levels).
- Enforced by the system, not the user.
- Common in military, government, and high-security environments.

Benefits:

- Strong, centralized control.
- Very secure for sensitive data.

Drawbacks:

- Inflexible and hard to manage.
- Not practical for most business environments.

RBAC (Role-Based Access Control)

Access is tied to job roles, not individuals. The HR Manager role gets access to employee records. The Developer role gets access to code repositories. When someone changes jobs, you change their role, permissions update automatically.

This is the most common model in enterprises. If you only remember one, make it this one.

Summary:

- Access is tied to job roles (e.g., HR Manager, Developer, CEO).
- Permissions are granted to roles, not individuals.
- The most common model in enterprises.

Benefits:

- Scalable and easy to manage.
- Supports least privilege by default.

Drawbacks:

- Roles must be well-defined, and poor design leads to over-privilege.
- Not flexible for context-specific access needs.

ABAC (Attribute-Based Access Control)

Access decisions are based on attributes such as who you are, what device you're using, where you are, what time it is. More flexible than RBAC, but more complex to set up. Common in cloud and zero-trust environments.

Summary:

- Access depends on attributes of the user, object, and environment.
- These attributes can belong to subjects, objects, actions, or context
- Examples: department, location, device, time of day.

Benefits:

- Extremely flexible and fine-grained.
- Ideal for dynamic, modern environments.

Drawbacks:

- Complex to configure and audit.
- Difficult to troubleshoot when access is denied unexpectedly.

Want the full breakdown with real-world examples and a quiz? [Read the full article here.](#)

Model	Who Decides Access?	Best For
DAC	The resource owner	Small teams, personal files
MAC	The system (based on labels)	Military, government, classified data
RBAC	Job roles	Most enterprises — the most common model
ABAC	Attributes (role + location + time + device)	Complex, dynamic environments
Rule-Based	System-enforced rules (time, events)	Adding dynamic rules on top of RBAC

Exam & Interview

Exam scenario tip: Questions often give you a scenario (like Anna, Tom, and Lisa) and ask which model fits best. The answer is almost always RBAC for a standard enterprise.

If the scenario mentions security labels or classifications, the answer is typically MAC.

If it mentions dynamic, context-based rules, think ABAC.

Interview Q: What access control model would you recommend for a company of 500 people?

Answer: RBAC. It scales well, enforces least privilege by design, and is easy to manage by assigning permissions to roles rather than individuals.

Key Takeaways

- **IAM:** controls who can access what, and what they can do once they're in
- **Authentication vs Authorisation:** verifying identity vs granting permissions.
- **Least Privilege:** give users only the access they need, nothing more
- **DAC:** owner decides; flexible but hard to scale
- **MAC:** system decides based on labels; used in high-security environments
- **RBAC:** role decides; the standard model in most enterprises
- **ABAC:** attributes decide; flexible and modern, but complex

Chapter Challenge

Head over to the full article and leave a comment answering:
"Anna from Finance, Tom from IT, Lisa from HR. Which access control model would you use to manage their access, and why?"

This type of scenario question is a favourite in Security+, ISC2 CC, and entry-level interviews. Nail it, and you will stand out.

[Access Controls: Who Gets the Keys? →](#)

I read every comment and will give you feedback.

And if your answer is correct, I'll give you a 3-month paid subscription to [Decoded Security](#) for FREE. (No strings attached, no payment information required)

7. Incident Response

What Is Incident Response?

Incident response (IR) is the structured approach an organization uses to detect, analyze, contain, eradicate, and recover from security incidents.

But here's the more important thing to understand:

Core idea: Incident response doesn't assume perfection. It assumes failure.

Its job is not to prevent incidents. Its job is to answer one question:

"How do we stay in control when something has already gone wrong?"

Without a structured response process, every incident becomes improvisation. And improvisation under stress is how small incidents become disasters.

Remember that.

The Purpose of Incident Response

This is a common exam trap. The purpose of incident response is NOT to prevent incidents.

Incident response exists to:

- Limit business impact
- Protect critical assets and data
- Preserve evidence and accountability
- Enable fast, informed decisions under pressure
- Restore trustworthy operations

In other words, incident response turns chaos into a managed situation.

The 7 Phases of Incident Response

For CC and CISSP, incident response is understood as a lifecycle, not a single action. Each phase has a specific purpose, and mixing them up is one of the most common exam and interview mistakes.

If you want to know more about incident response process, read the following article:

[The Incident Response Mistakes That End Interviews Early](#)

1. Detection & Identification

Key question: "Do we have an incident?"

Detection can come from technical sources (monitoring systems, SIEM, EDR), human sources (employees, administrators), or third parties (partners, service providers).

At this stage: you do not fix anything. You do not jump to conclusions. You confirm that an event actually qualifies as a security incident.

2. Response (Containment)

Key question: "How do we stop the damage from spreading?"

Containment focuses on isolating affected systems, preventing further compromise, and limiting business impact. Speed matters more than perfection here.

3. Mitigation (Eradication)

Key question: "How do we properly eliminate the threat?"

This phase focuses on removing adversarial control from affected systems. It includes removing malware, eliminating persistence mechanisms, and closing exploited vulnerabilities.

4. Reporting

Key question: "What must be documented, and who needs to know?"

Proper reporting ensures legal, regulatory, and executive readiness. An incident report typically includes:

- Summary of the incident
- Indicators of compromise
- Actions taken
- Chain of custody for all evidence
- Impact assessment
- Next steps to be taken

5. Recovery

Key question: "Can we trust these systems again?"

Recovery aims to restore full, trustworthy functionality. It requires significant testing and verification that affected systems are truly clean and properly configured.

Recovery is complete only when systems are both operational AND trustworthy.

6. Remediation

Key question: "How do we make sure this never happens again?"

Remediation focuses on long-term risk reduction. It identifies control gaps and determines which controls must be implemented or modified.

7. Lessons Learned

This phase occurs once the incident is fully closed. It answers three questions:

- What happened?
- What did we learn?
- How can we do it better next time?

Lessons learned drive process improvements, training updates, and policy enhancements.

Quick Reference: The 7 Phases

Phase	Key Question	Common Mistake
Detection & Identification	Do we have an incident?	Jumping to response before confirming
Response (Containment)	How do we stop it spreading?	Skipping containment to go straight to fix
Mitigation (Eradication)	How do we eliminate the threat?	Thinking clean = trusted
Reporting	What do we document?	Documenting after the fact instead of during
Recovery	Can we trust these systems again?	Confusing availability with trustworthiness
Remediation	How do we prevent recurrence?	Fixing symptoms, not root causes
Lessons Learned	What did we learn?	Skipping this phase entirely

Exam & Interview Tips

For exams and interviews, these distinctions are critical:

These are NOT the same	Why it matters
Detection ≠ Response	Identifying an event doesn't mean you've acted on it
Containment ≠ Eradication	Stopping spread is different from removing the threat
Recovery ≠ Remediation	Getting back online is different from fixing root causes
Lessons Learned ≠ Blame	The goal is improvement, not assigning fault

Interview Q: What is the purpose of incident response?

Answer: The purpose is not to prevent incidents. It is to limit business impact, preserve evidence, enable controlled decision-making, and restore trustworthy operations as quickly as possible. Prevention is handled by other security controls.

Interview Q: What is the difference between containment and eradication?

Answer: Containment stops the damage from spreading by isolating affected systems. Eradication removes the actual threat, including malware, backdoors, and exploited vulnerabilities. You contain first, then eradicate. Skipping containment means the threat can spread while you try to clean up.

Key Takeaways

- Incident response assumes failure. It is about control, not prevention.
- The lifecycle has 7 phases, each with a specific purpose.
- Detection, containment, eradication, recovery, and remediation are distinct processes.

- Documentation (reporting) is not optional. If it isn't documented, it didn't happen.
- Lessons learned is where incident response loops back to improve the whole system.

Chapter Challenge

Let's make this simple.

Go to the article: [The Incident Response Mistakes That End Interviews Early](#)

In the comments, answer this in just a few words:

What is the difference between containment and eradication?

That's it.

No long explanation needed. Just define each in one sentence.

If you answer correctly, I'll give you 1-month of [Decoded Security paid subscription](#) for free.

I read every comment and will give you feedback.

8. Governance, Policies & Compliance

Okay, now I'm going to say something you probably don't want to hear. This chapter is about policies. And yes, it sounds boring.

But here's the truth: most real-world security failures don't happen because of missing technical controls. They happen because nobody wrote down what the rules were, or nobody followed them.

If you want to work in cybersecurity, you need to understand how organizations define, communicate, and enforce their security expectations. That's what this chapter is about.

What Is Governance?

Governance is the framework that ensures an organization is being run responsibly and securely.

In cybersecurity, governance answers questions like:

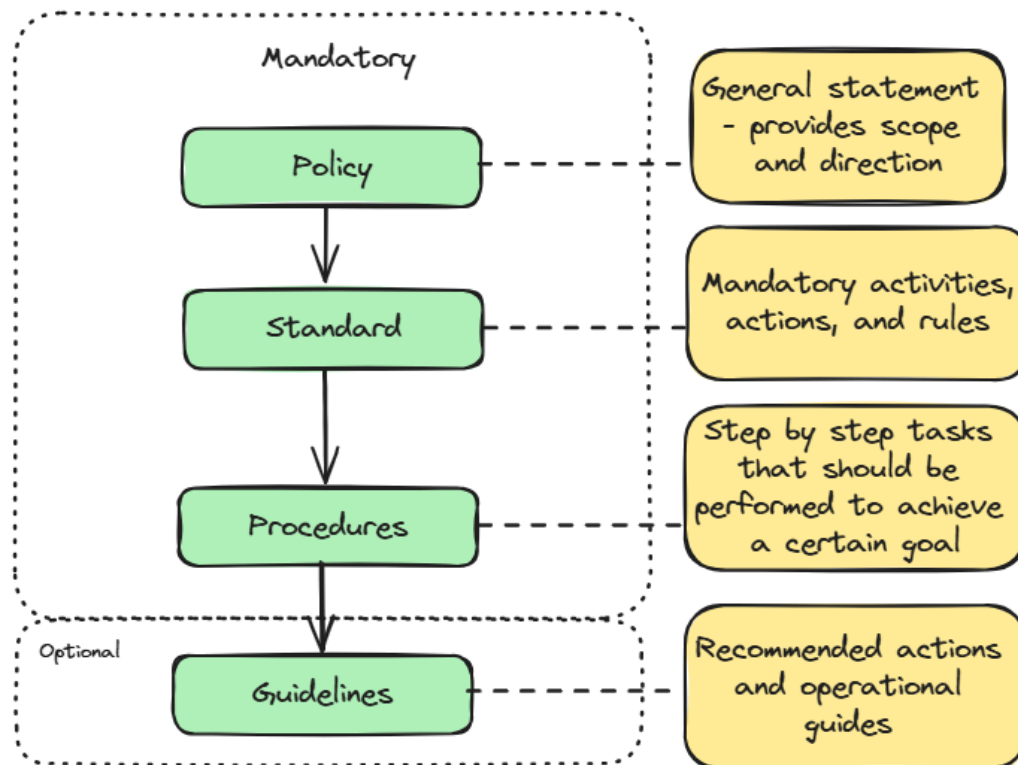
- Who is responsible for security decisions?
- What rules must everyone follow?
- How do we know the rules are being followed?
- What happens when they're not?

Governance is not a technical tool. It's a management concept. And that's exactly why it matters, because security doesn't start with technology. It starts with decisions.

The Building Blocks: Policy, Standard, Procedure, Guidelines

These four terms are used constantly in cybersecurity. They're also constantly confused.

Let's fix that.



Term	What it is	Mandatory?
Policy	A high-level statement defining what must be done and why. Comes from management.	Yes
Standard	A specific, measurable rule defining exactly what must be used or followed.	Yes
Procedure	A step-by-step guide explaining how to actually implement a policy or standard.	Yes
Guideline	An optional recommendation or best practice. Covers the grey areas.	No

Important: Standards are always unambiguous, detailed, and measurable. If it can't be measured, it's not a standard, it's a guideline.

How They Connect

Think of it as a hierarchy. Management sets the direction. Everyone else figures out how to get there.

- Policy sets the goal — the 'what and why'
- Standard defines the specific requirement — the 'what exactly'
- Procedure provides the step-by-step instructions — the 'how'
- Guideline offers optional advice — the 'consider doing this'

Each layer builds on the one above. You can't write a procedure without a standard. You can't write a standard without a policy.

A Real-World Example: The Coffee Shop

Here's how all four terms look in a single scenario. Imagine a coffee shop protecting its cash register.

Term	Example	Plain-English Meaning
Policy	Only authorized staff are allowed to access the cash register.	High-level rule: what & why
Standard	The cash register must be protected with a lock that meets Security Grade A.	Defines the required level: what exactly
Procedure	Step 1: Take the key from the manager's office. Step 2: Unlock the register before opening. Step 3: Lock it during breaks.	Step-by-step instructions: how
Guideline	It's recommended to change the lock code every 3 months and avoid sharing keys.	Optional best practice: suggested, not mandatory

Notice how each level becomes more specific and actionable. The policy sets the goal. The procedure tells you exactly what to do on Monday morning.

Want more examples and a quiz to test yourself?

Read the full article: [Security Policies, Standards, and Procedures: The Boring Stuff That Actually Saves You on Decoded Security.](#)

Exam & Interview Tips

Interview Q: What is the difference between a policy and a procedure?

Answer: A policy is a high-level statement from management that defines what must be done and why. A procedure is a detailed, step-by-step guide that explains how to implement that policy in practice. Policies set the direction. Procedures make it actionable.

Exam trap: Guidelines are optional. Standards and procedures are mandatory. If an exam question uses the word 'recommended,' think guideline, not standard.

Interview Q: Why do organizations need security policies if they already have technical controls?

Answer: Technical controls protect systems, but policies define the rules that everyone must follow: employees, managers, and third parties. Without policies, controls have no context. You can't enforce something that was never written down.

Key Takeaways

- Governance defines who is responsible for security and how decisions are made.
- Policy tells you what must be done and why. It comes from management.
- Standard tells you exactly what must be used or followed. Specific and measurable.
- Procedure tells you how to do it, step by step.
- Guideline is optional advice. Not mandatory.
- Compliance means meeting external requirements set by laws and regulations.
- Policies are the foundation. Without them, security is just a collection of disconnected tools.

Chapter Challenge

Understanding the difference between policies, standards, procedures, and guidelines is one of the most common topics in cybersecurity interviews.

If you want to make sure you truly understand it, try this:

1. **Read the full article:**
[Security Policies, Standards, and Procedures: The Boring Stuff That Actually Saves You](#)
2. **Take the short quiz at the end of the article.**
3. **Post your score in the comments.**

If you score 8/10 or higher, I'll give you 1 month of Decoded Security paid subscription for free.

Let's see who actually understands the difference.

Congratulations! You are making a great progress! Trust me, by knowing these things you are already ahead of most people who claims they want to get into cybersecurity!

9. Security Control Types

As a reward for making it through the boring chapter, let's take a look at something really interesting.

Now it's time to talk about actual security controls.

Here's a question that trips up a lot of beginners:
"What controls do you have in place?"

Most people think of firewalls. Maybe antivirus. And then they go blank.

But cybersecurity controls come in many forms, from a locked server room door to a phishing awareness training.

Without a framework for thinking about them, it's easy to miss entire categories of risk. That's exactly what this chapter fixes.

Two Ways to Classify Controls

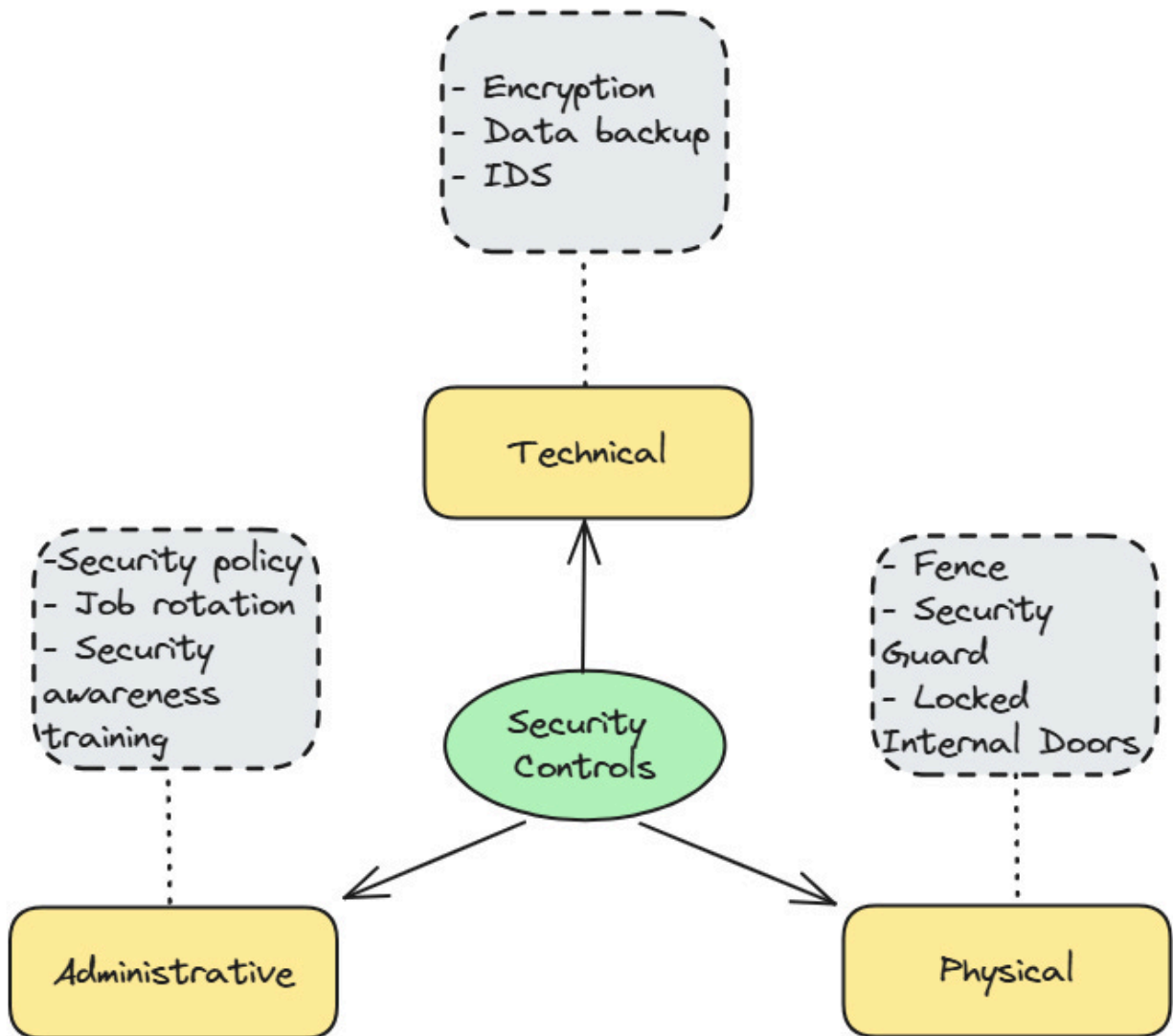
There are two independent ways to categorize security controls.
And here's the key insight:

Core idea: Both classifications are valid. Both are used together. One tells you HOW a control works. The other tells you WHY it exists.

Classification 1: How Is It Implemented?

This classification groups controls by how they are deployed. There are three categories:

Category	What it means	Examples
Administrative	Non-technical methods. Human-driven.	Security policies, training, hiring practices, risk assessments
Technical (Logical)	Implemented through hardware or software.	Firewalls, encryption, antivirus, MFA
Physical	Protects the physical environment.	Locks, fences, cameras, security guards



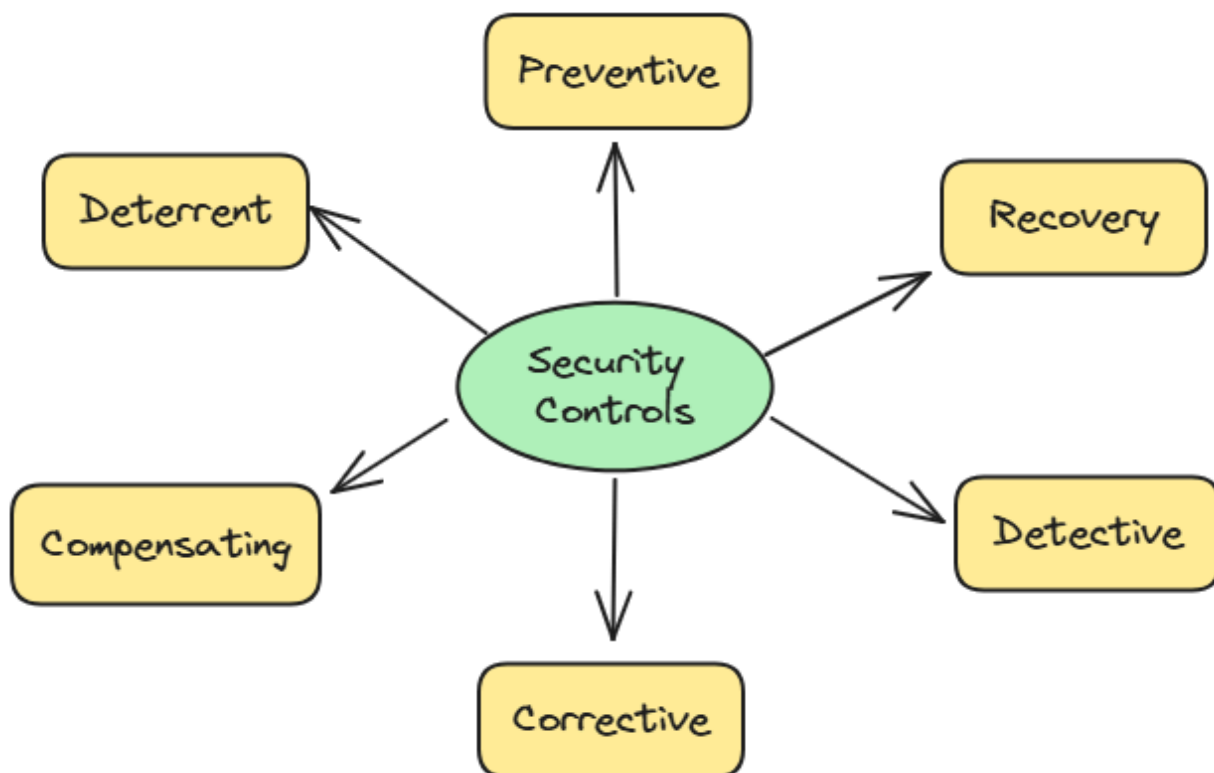
Notice that not everything is a piece of software. A locked door is a security control. A hiring background check is a security control. Keep that in mind.

Classification 2: What Purpose Does It Serve?

This second classification looks at why a control exists. What is it designed to do?

Type	What it does	Example
Preventive	Stops bad things from happening in the first place.	Encryption, access controls, firewalls
Detective	Identifies and alerts when something has happened.	Intrusion detection systems, log monitoring, CCTV
Corrective	Fixes or limits damage after detection.	Patching systems, restoring backups, isolating infected machines

Deterrent	Discourages attackers through fear of consequences.	Warning banners, security cameras, visible guards
Recovery	Restores operations after an incident.	Disaster recovery plans, backups, failover systems
Compensating	An alternative when the primary control isn't feasible.	Manual review when automation isn't available



Why This Matters in Interviews

This comes up constantly in Security+, ISC2 CC, and CISSP. Interviewers love to give you a scenario and ask you to categorize the controls involved.

If you can say "this is a technical, preventive control" and explain why, you immediately sound like someone who understands security at a conceptual level.

Most candidates can only name tools. You'll be able to explain what those tools actually do and why they exist.

Exam & Interview Tips

Interview Q: Give me an example of a preventive control and a detective control.

Answer: A firewall is a technical, preventive control. It blocks unauthorized traffic before an incident occurs. An intrusion detection system (IDS) is a technical, detective control, it identifies and alerts on suspicious activity after it has happened.

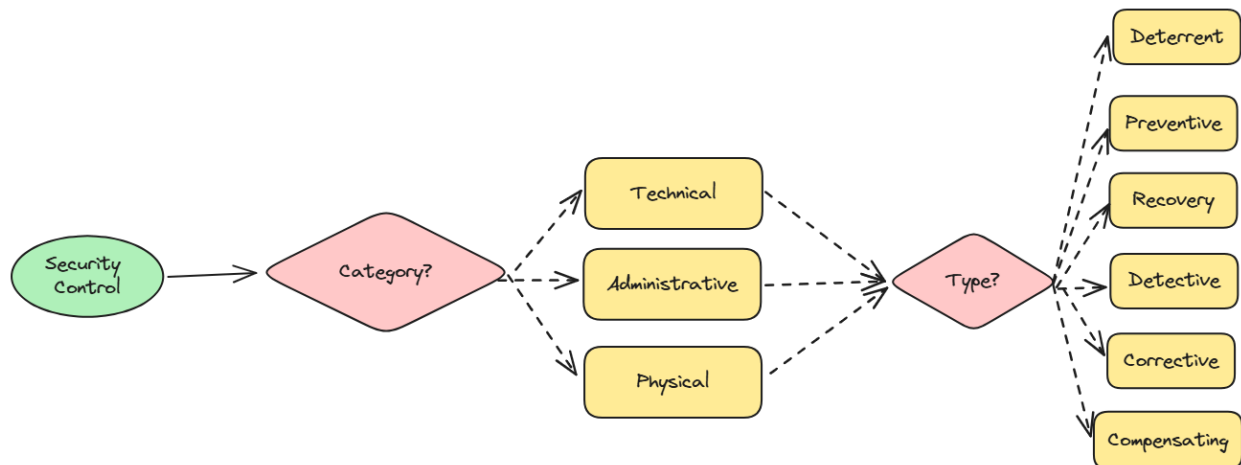
Exam trap: Deterrent and preventive controls are NOT the same. A deterrent discourages an action. A preventive control actually stops it. A warning sign is a deterrent. A locked door is preventive.

Interview Q: What is a compensating control?

Answer: A compensating control is an alternative control used when the primary or ideal control isn't feasible. For example, if automated log monitoring isn't available, a manual daily review of logs could act as a compensating control.

Key Takeaways

- Security controls are not just firewalls. They include policies, training, locks, cameras, and more.
- Controls are classified by how they work: Administrative, Technical, or Physical.
- Controls are also classified by why they exist: Preventive, Detective, Corrective, Deterrent, Recovery, or Compensating.
- Both classifications apply to the same control at the same time.
- Interviewers love asking you to categorize controls. Practice it.



Chapter Challenge

Go to the article: [Cybersecurity Controls from Zero to Hero](#)

Take the 10-question quiz at the end of the article.

Then post your score in the comments here:

"I scored X/10. Here's the one control type I found most confusing and what I now understand about it."

Score 8/10 or higher and I'll give you 1 month of Decoded Security paid subscription for free.

I read every comment and will give you feedback.

Cloud Security Basics

Here's a reality check.

The majority of organizations Here's a reality check.

The majority of organizations you will ever work for don't run their own servers anymore.

They use the cloud.

That means the majority of security work you'll do in your career will involve cloud environments in some way.

You don't need to be a cloud architect. But if you walk into an interview with zero understanding of cloud computing, it will show.

This chapter gives you what you need.

Why Cloud Security Is Non-Negotiable

The cloud changed everything about how organizations build and run their IT systems. Instead of buying and maintaining physical servers, companies now rent computing power, storage, and software from providers like AWS, Microsoft Azure, and Google Cloud.

This shift creates new security challenges that simply didn't exist before:

- Your data lives on someone else's infrastructure
- Access happens over the public internet
- Configuration mistakes are the number one cause of cloud breaches
- The boundary between 'inside' and 'outside' the network has essentially disappeared

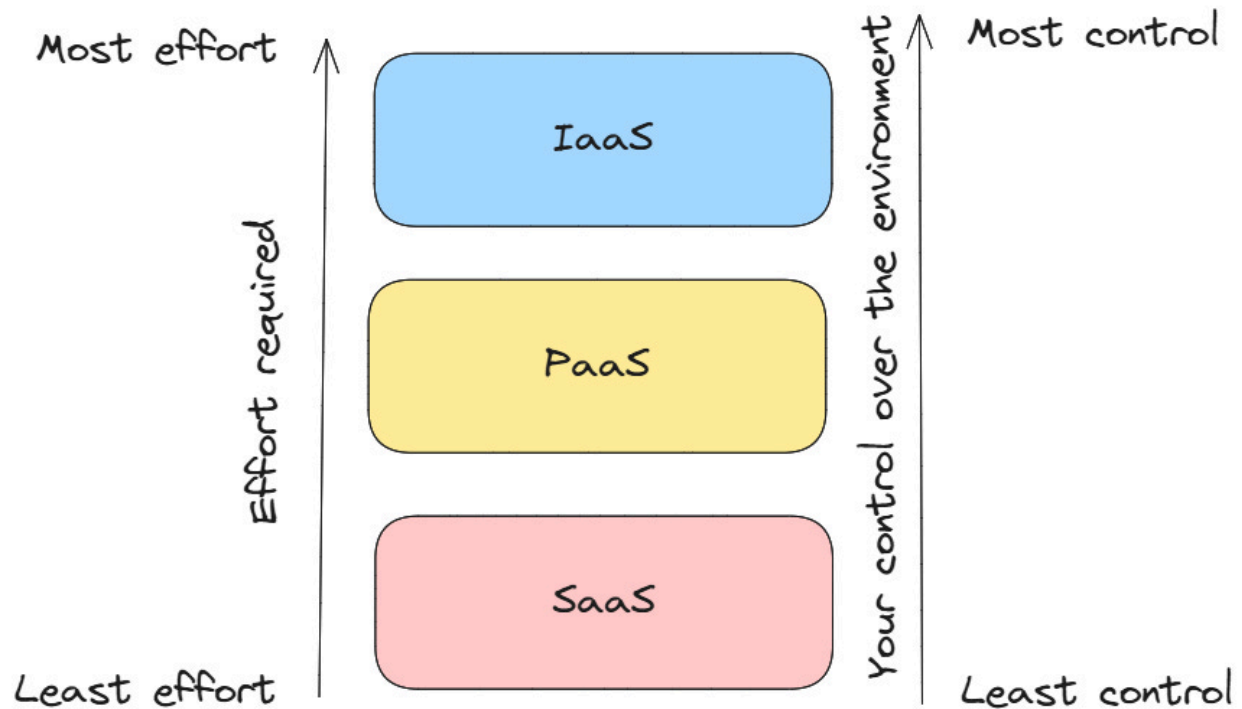
Key insight: In the cloud, misconfiguration is the attacker's best friend. Most cloud breaches aren't caused by sophisticated hacking. They're caused by a storage bucket left publicly accessible or permissions set too broadly.

The 3 Service Models You Must Know

This is one of the most tested areas in Security+, ISC2 CC, and CISSP. The key question for each model is: who is responsible for what?

Model	What you get	You manage	Provider manages	Example
IaaS (Infrastructure as a Service)	Raw computing resources: servers, storage, networking.	OS, apps, data, security config	Physical hardware, network, data center	AWS EC2, Azure VMs
PaaS (Platform as a Service)	A ready-made platform to build and deploy apps.	Your application and data	Infrastructure + runtime + OS	Google App Engine, Heroku
SaaS (Software as a Service)	A fully working application, ready to use.	Your data and user access	Everything else	Gmail, Microsoft 365, Salesforce

Simple way to remember it: IaaS = rent the building (you furnish it). PaaS = rent the kitchen (you cook). SaaS = order the meal (someone else does everything).



The more convenience you get, the less control you have. And less control means you rely more heavily on the provider's security.

If you need more details to understand different service models, read it here: [The Cloud Isn't Magic! It's Just Rented IT.](#)

The 4 Deployment Models

Cloud resources can be deployed in different ways depending on who owns them and who can access them.

Model	What it means	Best for
Public Cloud	Shared infrastructure managed by a provider. You share the environment with other customers (but not their data).	Cost-efficient workloads, most organizations
Private Cloud	Dedicated infrastructure just for your organization. More control, more cost.	Sensitive data, strict compliance requirements

Community Cloud	Shared between a group of organizations with similar needs (e.g. hospitals, government agencies).	Regulated industries needing collaboration
Hybrid Cloud	A mix of public and private. Use the private cloud for sensitive data, public cloud for everything else.	Organizations needing flexibility and control

The Shared Responsibility Model

This is the most important cloud security concept you need to understand. It's tested constantly.

In the cloud, security is not entirely the provider's job. It's split between the provider and the customer.

Core rule: The provider secures the cloud infrastructure. You are responsible for securing what you put in it.

Here's how it breaks down depending on the service model:

Responsibility	IaaS	PaaS	SaaS
Physical security	Provider	Provider	Provider
Network infrastructure	Provider	Provider	Provider
Operating system	Customer	Provider	Provider
Application	Customer	Customer	Provider
Data	Customer	Customer	Customer
Access & identity	Customer	Customer	Customer

Exam trap: A cloud provider being hacked does not automatically mean you're off the hook. Your data, your access controls, and your configurations are always your responsibility, regardless of the service model.

Exam & Interview Tips

Interview Q: What is the shared responsibility model in cloud security?

Answer: In cloud computing, security responsibilities are split between the cloud provider and the customer. The provider is responsible for securing the underlying infrastructure. The customer is responsible for securing their data, applications, access controls, and configurations. The exact split depends on whether you're using IaaS, PaaS, or SaaS — but data and identity are always the customer's responsibility.

Interview Q: What is the difference between IaaS, PaaS, and SaaS?

Answer: IaaS gives you raw infrastructure — you manage the OS and everything above it. PaaS gives you a platform to build applications — you manage your app and data. SaaS gives you a finished application — you manage only your data and user access. The more managed the service, the less control you have over the underlying environment.

Exam scenario tip: If an exam question mentions a company storing sensitive customer data in a public S3 bucket — that's the customer's fault, not AWS. Shared responsibility. The provider secured the infrastructure. The customer misconfigured their storage.

Key Takeaways

- Cloud computing = rented IT. Instead of owning servers, organizations rent resources from providers.
- The three service models are IaaS, PaaS, and SaaS. More convenience = less customer control.
- The four deployment models are Public, Private, Community, and Hybrid.
- The shared responsibility model defines who is accountable for what. Your data and your access controls are always your responsibility.
- Misconfiguration is the leading cause of cloud breaches. Understanding this makes you a stronger candidate.

Chapter Challenge

Go to the article: [The Cloud Isn't Magic! It's Just Rented IT.](#)

In the comments, answer this question:

"Your company stores customer data in a cloud database. The cloud provider gets hacked and the data is exposed. Who is responsible, the provider or your company?"

Explain your answer using the shared responsibility model.

If you answer correctly and explain your reasoning clearly, I'll give you 1 month of Decoded Security paid subscription for free.

I read every comment and will give you feedback.

Congratulations!

You've made it through all 10 topics.

Take a moment to appreciate that. Most people who say they want to get into cybersecurity never get this far.

You now have a clear mental model of the concepts that actually matter in interviews. The CIA Triad. Risk management. Networking. Cryptography. IAM. Incident response. Governance. Controls. Cloud.

That's not a small thing.

The next step is to go deeper on the topics where you felt least confident, and to start applying these concepts in practice. Use the article challenges. Read the linked resources. Engage with the [Decoded Security](#) community.

The goal was never to memorize everything.

The goal was to give you the foundation to keep learning with confidence.

You have that now.

Good luck. I'm rooting for you.

— Erich

A Small Reward for Finishing

If you finished this book, you deserve something extra.

You can get 50% off any Decoded Security product.

These guides and labs are designed to help you move from theory to practical skills.

Use the code:

Finisher

Browse all products here: [Decoded Security - Products](#)

Stay Connected

If you want to keep learning cybersecurity in a simple and practical way, you can also follow Decoded Security.

I regularly publish:

- beginner-friendly cybersecurity explanations
- practical labs
- career advice for people entering the field

You can find it here:

👉 <https://www.decodedsecurity.com>